AEGISAI ENTERPRISE EDITION

SUITE DE DOCUMENTACIÓN TÉCNICA

Manual de Gobernanza y Políticas AIMS ISO/IEC 42001:2023

Política Corporativa de IA, Evaluación de Impacto (AIIA), Canal Ético, Inventario A.4.1 y Revisión por la Dirección

Versión de Plataforma:	**2.5.0 Enterprise Edition**
Alcance Normativo:	**OWASP AISVS v1.0, ISO/IEC 42001:2023, Google Cloud Security**
Licencia:	**Apache License 2.0 (Open Source)**

PLATAFORMA DE ASEGURAMIENTO AEGIS AI

Manual de Gobernanza, Políticas y Cumplimiento del Sistema de Gestión de IA (AIMS — ISO/IEC 42001:2023)

Versión: 2.5.0 Enterprise (Edición 2026)

Alineación Normativa: ISO/IEC 42001:2023 (Cláusulas 4–10 y Anexo A.2–A.10) y OWASP AI-SVS v1.0

Clasificación: Manual Corporativo Obligatorio de Gobernanza de IA, Carta de Políticas y Registro de Evidencia Operativa

ID de Documento: `AIMS-GOV-2026-001`

Aprobado Por: Chief Information Security Officer (CISO), Chief AI Officer (CAIO) y Comité Corporativo de Gobernanza de IA

---

1. Contexto de la Organización y Alcance del AIMS (Cláusulas 4.1, 4.2, 4.3, 4.4)

1.1 Comprensión de la Organización y de su Contexto (`Clause 4.1`)

AegisAI opera como un **Sistema Autónomo de Aseguramiento de Cumplimiento y Ciberseguridad (Motor de Recomendación y Apoyo a la Decisión)** diseñado para entornos empresariales regulados (Servicios Financieros, Retail, Salud y Sector Público). Bajo la norma ISO/IEC 42001:2023 `Clause 4.1`, la organización ha determinado formalmente las cuestiones internas y externas que afectan a su Sistema de Gestión de Inteligencia Artificial (AIMS):

1. **Rol Organizacional en la Cadena de Valor de IA:**
   - **Desarrollador e Integrador de Sistemas de IA:** AegisAI diseña, desarrolla y mantiene el orquestador de evaluación Map-Reduce multinormativo (`server.ts`), el motor determinista de calificación y el pipeline de síntesis de arquitectura remediada (`remediatedArchitectureGenerator.ts`).
   - **Consumidor de Servicios de IA (Cloud PaaS):** AegisAI consume modelos fundacionales (`gemini-3.8-flash` , `gemini-3.1-flash-lite` , `gemini-3.7-flash`) hospedados en **Google Cloud Vertex AI** bajo acuerdos empresariales de cero retención de datos para entrenamiento.
2. **Contexto Externo y Matriz Regulatoria:**
   - **Ciberseguridad y Aseguramiento Técnico:** OWASP Artificial Intelligence Security Verification Standard (AI-SVS v1.0, Niveles L1, L2 y L3).
   - **Gobernanza y Gestión de IA:** ISO/IEC 42001:2023 y NIST AI Risk Management Framework (AI RMF 1.0).
   - **Marcos Legales Jurisdiccionales:** Reglamento de IA de la Unión Europea (EU AI Act 2024/1689), Ley Federal de Protección de Datos Personales en Posesión de los Particulares (*LFPDPPP* / INAI) y Ley Federal de Protección al Consumidor (*LFPC* / PROFECO Art. 76 Bis).
3. **Contexto Interno y Objetivos Estratégicos:**
   - Garantizar **100% de factualidad determinista (`temperature: 0.0`)** con citas textuales literales obligatorias (`fuenteEvidencia` y `textoEvidencia`).
   - Mantener un límite estricto **Human-in-the-Loop (HITL)**: AegisAI emite dictámenes técnicos de apoyo a la decisión; la aprobación regulatoria vinculante requiere firma de un auditor humano certificado.

1.2 Comprensión de las Necesidades y Expectativas de las Partes Interesadas (`Clause 4.2`)

En cumplimiento con `Clause 4.2`, el AIMS mantiene un **Registro Formal de Partes Interesadas y SLAs** revisado trimestralmente por el Comité de Gobernanza de IA:

Parte Interesada	Rol / Relación	Expectativas y Requisitos Clave	SLA / Mecanismo de Control en el AIMS
Auditores de Ciberseguridad (Internos y Externos)	Operadores Primarios	Cero alucinaciones, citas documentales literales, puntajes reproducibles y trazabilidad forense inmutable.	`temperature: 0.0`, esquema JSON estricto y registros inmutables en Firestore (`allow delete: if false;`).
Equipos de Ingeniería Auditados y Líderes Técnicos	Sujetos Evaluados	Evaluación justa, justificación transparente de fallos, código de remediación accionable y derecho de impugnación.	Recetas 4D, Cookbook de Arquitectura Remediada y Canal de Impugnación (`ai-appeals@aegisai.enterprise`, **SLA: 5 días hábiles**).
Alta Dirección Corporativa (CISO / DPO / Legal)	Patrocinadores del AIMS	Cumplimiento integral con OWASP AI-SVS, ISO/IEC 42001, EU AI Act y LFPDPPP; aislamiento total entre tenants.	Aislamiento por dominio (`VITE_ALLOWED_DOMAINS`, Cloud IAP, reglas Firestore por tenant/owner) y Revisión por la Dirección (`Clause 9.3`).
Reguladores Externos (INAI, PROFECO, EU AI Office)	Autoridades Supervisoras	Inventario de activos de IA demostrable, evaluaciones de impacto algorítmico (AIIA) y retención forense de 7 años.	Retención inmutable de 7 años en Cloud Firestore (`aegis-ai-db`) y exportación de paquetes de evidencia PDF/Markdown.
Proveedores Cloud y de Modelos (Google Cloud / Vertex AI)	Cadena de Suministro	Cumplimiento de Políticas de Uso Aceptable, prevención de abuso Denial-of-Wallet (DoW) y autenticación IAM segura.	Cuenta de servicio `aegis-runner-sa` (ADC), limitador de tasa y presupuesto de tokens (`C11.1`) y detector crescendo (`C02.10`).

---

2. Liderazgo, Política Corporativa de IA y Estructura de Gobernanza (Cláusulas 5.1, 5.2, 5.3, Anexo A.2.1, A.2.3, A.3.2, A.3.3)

2.1 Liderazgo y Compromiso (`Clause 5.1`)

La Alta Dirección (CISO y CAIO) demuestra su liderazgo y compromiso formal con el AIMS (`Clause 5.1`) mediante:

1. La constitución formal del **Comité Corporativo de Gobernanza de IA** (integrado por Ciberseguridad, Legal/Privacidad, Ingeniería de IA y Gestión de Riesgos).
2. La asignación presupuestal anual dedicada para cuotas de inferencia en Vertex AI, pruebas automatizadas de seguridad (`npm run test:security`) y auditorías externas.
3. La integración obligatoria de compuertas de cumplimiento AIMS en el ciclo de vida SDLC y en el pipeline de despliegue (`deploy_cloud_run.sh`).

2.2 Política Corporativa de Inteligencia Artificial (`Clause 5.2` y `Annex A.2.1`)

> **DECLARACIÓN DE POLÍTICA (`POL-AIMS-001` — Aprobada por CISO y Comité Ejecutivo):**

> *"Todo sistema de Inteligencia Artificial desarrollado, desplegado u operado en la organización —incluyendo la plataforma AegisAI— deberá regirse por los principios de **Verificabilidad Determinista, Seguridad Zero-Trust, Privacidad desde el Diseño, Supervisión Humana Efectiva y Escalamiento Ético sin Represalias**."*

La Política Corporativa de IA (`Clause 5.2` , `A.2.1`) establece seis mandatos vinculantes:

1. **Adjudicación Basada Exclusivamente en Evidencia:** Ningún evaluador de IA puede aprobar (`Aprobado`) un control sin extraer una cita textual literal y verificable de la evidencia documental o manifiesto cloud.
2. **Supervisión Humana Obligatoria (HITL):** AegisAI opera estrictamente como sistema consultivo de apoyo a la decisión.
3. **Cero Exposición No Autenticada:** Todo despliegue productivo se protege detrás de **Cloud Identity-Aware Proxy (IAP)** y **Firebase Authentication** restringido a dominios corporativos autorizados.
4. **Mínimo Privilegio Estricto:** La identidad de ejecución (`aegis-runner-sa`) cuenta únicamente con `roles/aiplatform.user` y `roles/datastore.user` , prohibiendo roles amplios como `roles/viewer` , `roles/editor` o `roles/owner` .
5. **Integridad Criptográfica de Cadena de Suministro:** Todos los catálogos normativos se verifican al arranque contra hashes SHA-256 en `config/frameworks/integrity-manifest.json` (`C01.4`).
6. **Mejora Continua:** Compromiso formal de mejora continua del AIMS mediante KPIs cuantitativos (`Clause 9.1`), auditorías internas semestrales (`Clause 9.2`) y revisiones trimestrales por la dirección (`Clause 9.3`).

2.3 Revisión de la Política de IA (`Annex A.2.3`)

De conformidad con `Annex A.2.3` , la Política Corporativa de IA (`POL-AIMS-001`) se somete a:

- **Revisión Anual Programada:** Ejecutada cada Q4 (octubre) por el Comité de Gobernanza de IA.
- **Revisión Extraordinaria por Eventos:** Activada dentro de los **15 días naturales** posteriores a cambios regulatorios mayores, migraciones de familia de modelos fundacionales o incidentes de seguridad P1.

2.4 Canal Confidencial de Denuncia y Escalamiento Ético (`Annex A.3.3`)

Para satisfacer `Annex A.3.3` (*Reporting of concerns*), AegisAI dispone de un canal confidencial y anónimo para reportar preocupaciones éticas, sesgos sistémicos, alucinaciones o vulnerabilidades de seguridad en IA:

- **Canales de Reporte:** Enlace directo integrado en la pantalla de acceso (`Login.tsx`) y en el pie de página permanente de la aplicación (`App.tsx`): `mailto:ai-ethics-whistleblower@aegisai.enterprise` y portal anónimo `https://ethics-hotline.aegisai.enterprise/report` .
- **Garantía de Cero Represalias:** La política `POL-AIMS-003` prohíbe estrictamente cualquier represalia laboral o contractual contra denunciantes de buena fe.
- **SLA de Atención:** Acuse de recibo en **24 horas**, investigación independiente en **10 días hábiles** y reporte consolidado en la Revisión por la Dirección (`Clause 9.3`).

---

3. Programa de Competencia, Capacitación y Concientización (Cláusulas 7.2, 7.3)

3.1 Matriz de Competencia y Certificación Obligatoria (`Clause 7.2`)

Bajo `Clause 7.2` , todo el personal involucrado en el desarrollo, operación o auditoría de AegisAI debe acreditar competencia técnica y normativa verificada:

Rol	Competencias Técnicas y Normativas Requeridas	Certificación / Evaluación Obligatoria	Periodicidad
Ingenieros de Plataforma de IA	Orquestación segura de LLMs, OWASP Top 10 for LLM v2025, defensa contra inyección (`C02.10`) y mínimo privilegio en GCP.	**Examen de Ingeniería Segura OWASP AI-SVS** ($\ge 85\%$) + Google Cloud Security Engineer.	Anual (12 meses)
Auditores AIMS y Oficiales de Cumplimiento	Auditoría de cláusulas y Anexo A de ISO/IEC 42001:2023, evaluación de impacto algorítmico (AIIA) y verificación de evidencia.	**Certificación ISO/IEC 42001 Lead Auditor / Implementer** + Taller de Calibración AegisAI.	Anual (12 meses)
Administradores DevSecOps y Cloud	Hardening de Cloud Run, Cloud IAP, VPC Serverless Access, rotación en Secret Manager y `firestore.rules`.	**Evaluación Operativa DevSecOps AegisAI** + Simulacro de Respuesta a Incidentes.	Semestral (6 meses)

3.2 Programa de Concientización Organizacional (`Clause 7.3`)

En cumplimiento con `Clause 7.3`, todos los usuarios autorizados reciben concientización continua sobre la Política Corporativa de IA (`POL-AIMS-001`), la Política de Uso Aceptable (`A.9.1`), su contribución a la eficacia del AIMS y las consecuencias de incumplimiento mediante avisos interactivos en `Login.tsx` y `App.tsx`.

---

4. Inventario de Activos de IA y Evaluación de Impacto Algorítmico (Anexo A.4.1, A.5.1, A.5.2, A.5.3)

4.1 Inventario Integral de Activos de IA (`Annex A.4.1`)

En cumplimiento con `Annex A.4.1` (*Documentation of resources*), la organización mantiene el **Registro Maestro de Recursos y Activos de IA (`AIMS-INV-A.4.1`)**:

- **Modelos Fundacionales:** `gemini-3.8-flash` (Primario), `gemini-3.1-flash-lite` (Fallback 1), `gemini-3.7-flash` (Fallback 2) en Google Cloud Vertex AI (`us-central1`).
- **Bases de Conocimiento Normativo:** `owasp-aisvs-context.md`, `iso-42001-context.md` y `config/frameworks/*.json`, protegidos en sistema de archivos de solo lectura (`/app`) y verificados con hashes SHA-256 (`config/frameworks/integrity-manifest.json`).
- **Infraestructura y Almacenamiento:** Cloud Run (`aegis-ai`), Cloud Firestore Native (`aegis-ai-db` en `nam5`) y Google Cloud Secret Manager (`aegis-admin-token`).

4.2 Proceso de Evaluación de Impacto de Sistemas de IA (`Annex A.5.1`)

Bajo `Annex A.5.1`, AegisAI exige una **Evaluación de Impacto Algorítmico (AIIA)** cuantitativa ($\text{RPN} = \text{Severidad} \times \text{Probabilidad} \times \text{Detectabilidad}$) antes de incorporar nuevos modelos fundacionales, marcos regulatorios o cambios en el algoritmo de calificación.

4.3 Evaluación de Impacto en Individuos y Grupos y Derecho de Impugnación (`Annex A.5.2`)

De conformidad con `Annex A.5.2`, se evalúan y mitigan los impactos sobre equipos de ingeniería auditados y usuarios finales (prevención de falsos positivos mediante citas textuales obligatorias y prevención de penalizaciones injustas mediante deduplicación de responsabilidad compartida). Cualquier líder técnico puede impugnar un dictamen algorítmico a través del canal **`ai-appeals@aegisai.enterprise`** (integrado en `Login.tsx` y `App.tsx`), garantizando revisión por un Auditor Líder humano en un plazo máximo de **5 días hábiles**.

4.4 Documentación y Retención Forense de Evaluaciones de Impacto (`Annex A.5.3`)

Bajo `Annex A.5.3`, todas las evaluaciones AIIA, reportes de auditoría (`audits/{auditId}`) y adendas de apelación se conservan de forma inmutable durante **7 años** en Cloud Firestore (`allow delete: if false;`).

---

5. Evaluación del Desempeño, Auditoría Interna y Revisión por la Dirección (Cláusulas 9.1, 9.2, 9.3)

5.1 Monitoreo, Medición, Análisis y Evaluación (`Clause 9.1` y OWASP `C08.4`)

En cumplimiento con `Clause 9.1` y OWASP `C08.4`, AegisAI mide continuamente indicadores clave de desempeño (KPIs) expuestos en tiempo real mediante `GET /api/admin/aims-telemetry`:

1. `KPI-AIMS-01` **(Tasa de Fundamentación Citatriz / Grounding Rate):** Meta $\ge 95.0\%$ de controles aprobados con cita literal verificable (`recordAimsEvaluationMetrics`).
2. `KPI-AIMS-02` **(Índice de Determinismo):** Meta 100.0% de inferencias ejecutadas con `temperature: 0.0`.
3. `KPI-AIMS-03` **(Latencia de Evaluación P95):** Meta $\le 180,000\text{ ms}$ por lote Map-Reduce.
4. `KPI-AIMS-04` **(Eficacia de Defensa Activa):** Registro en tiempo real de bloqueos por inyección (`C02.10`), límites Anti-DoW (`C11.1`) y protección SSRF (`C04.3`).

5.2 Programa de Auditoría Interna del AIMS (`Clause 9.2`)

Bajo `Clause 9.2`, el equipo independiente de Riesgo y Cumplimiento ejecuta **Auditorías Internas Semestrales del AIMS** (abril y octubre), incluyendo la meta-evaluación de la documentación y arquitectura de AegisAI contra OWASP AI-SVS v1.0 e ISO/IEC 42001:2023 y el seguimiento de acciones correctivas (CAPA).

5.3 Revisión por la Dirección (`Clause 9.3`)

Bajo `Clause 9.3`, el Comité Ejecutivo celebra **Revisiones Trimestrales por la Dirección** (Q1–Q4), evaluando métricas de `GET /api/admin/aims-telemetry`, resultados de auditorías internas, reportes éticos (`A.3.3`), apelaciones (`A.5.2`) y cambios regulatorios, emitiendo actas firmadas (`AIMS-MIN-9.3-YYYY-QX`).

---

6. Uso Responsable, Política de Uso Aceptable (AUP) y Monitoreo Post-Despliegue (Anexo A.9.1, A.9.2)

6.1 Uso Responsable y Política de Uso Aceptable (`Annex A.9.1`)

Para satisfacer `Annex A.9.1`, todo usuario acepta la **Política de Uso Aceptable (`AUP-AIMS-002`)** en la interfaz de inicio de sesión (`Login.tsx`) y pie de página (`App.tsx`), la cual restringe el uso del sistema a auditorías defensivas de ciberseguridad y exige validación humana antes de decisiones regulatorias vinculantes.

6.2 Procesos para el Uso Responsable y Monitoreo Continuo Post-Despliegue (`Annex A.9.2`)

En cumplimiento con `Annex A.9.2`, AegisAI ejecuta verificación criptográfica SHA-256 de sus catálogos normativos en cada arranque (`verifyNormativeSnapshotsIntegrity`), monitoreo continuo de fidelidad citatriz (`recordAimsEvaluationMetrics`) y recalibración normativa trimestral.